Exp 8: Configuring User Management and Role-Based Access Control (RBAC) in a Zoho Creator Application

1. Aim

To configure user management, permission sets, organizational roles, and record-level sharing for the **Loan Application & Pre-Screening Management** application in Zoho Creator. The design protects personal and financial data in **Loan_Application_Form** and **Loan_Application_Report** while giving applicants, loan officers, and administrators only the access required for their work.

2. Procedure

Phase A: Access User Permissions

Step 1: Open the Loan Application & Pre-Screening Management application and select **Settings** from the top navigation.

Step 2: Under **Permissions**, open **User Permissions**. Review the existing profiles shown for Admin, Applicant, Loan Officer, Read, and Write.

Phase B: Define Least-Privilege Permission Sets

Step 3: Select **Add Permission** and create permission sets that separate application administration, applicant submission, and loan-officer review.

Step 4: For the Applicant profile, permit creation of a loan enquiry and access only to approved applicant-facing pages. Do not grant access to browse Loan_Application_Report or other applicants' records.

Step 5: For the Loan Officer profile, grant the form and report rights required to review assigned applications, correct verified details, and update processing status. Restrict delete, bulk export, schema, and workflow administration unless bank policy explicitly allows them.

24140147

Phase C: Configure Roles and Record Visibility

Step 6: Open the **Roles** tab. Use the existing root role only as the administrative starting point, then model the operational hierarchy with a Bank Administrator or Branch Manager above Loan Officer roles.

Step 7: Keep prospective borrowers as applicant or portal users rather than placing them in the internal employee reporting hierarchy.

Step 8: In **Data Sharing**, define record visibility so a loan officer sees only assigned or policy-approved applications. Permit supervisory read access where required for quality review and audit.

Phase D: Apply Field and Action Restrictions

Step 9: Protect PAN_Number, Date_Of_Birth, Residential_Address, Monthly_Income, Existing_Liabilities, and Consent_For_Credit_Check. Mask or hide fields in views where full values are unnecessary.

Step 10: Separate form submission from credit-bureau processing. An Applicant can record consent, but only an authorized bank workflow or user may initiate the actual check.

Phase E: Verify the RBAC Design

- **Applicant test:** Can submit a valid Loan_Application_Form but cannot open another applicant's record.
- **Loan Officer test:** Can view and update assigned applications while restricted fields and prohibited actions remain unavailable.
- **Supervisor test:** Can review approved subordinate records according to the configured sharing rule.
- **Administrator test:** Can manage permission settings and application configuration, with audit logging enabled.
- **Negative test:** A user without the relevant permission receives no record data through forms, reports, exports, URLs, or API access.

Capture the role, permission set, test user, record scope, expected result, and actual result for each verification. The screenshots below document the available configuration screens; final access must be tested with separate user accounts.

24140104

3. Output

3.1 User Permissions Overview

The permissions list for the loan application displays Admin, Applicant, Loan Officer, Read, and Write profiles.

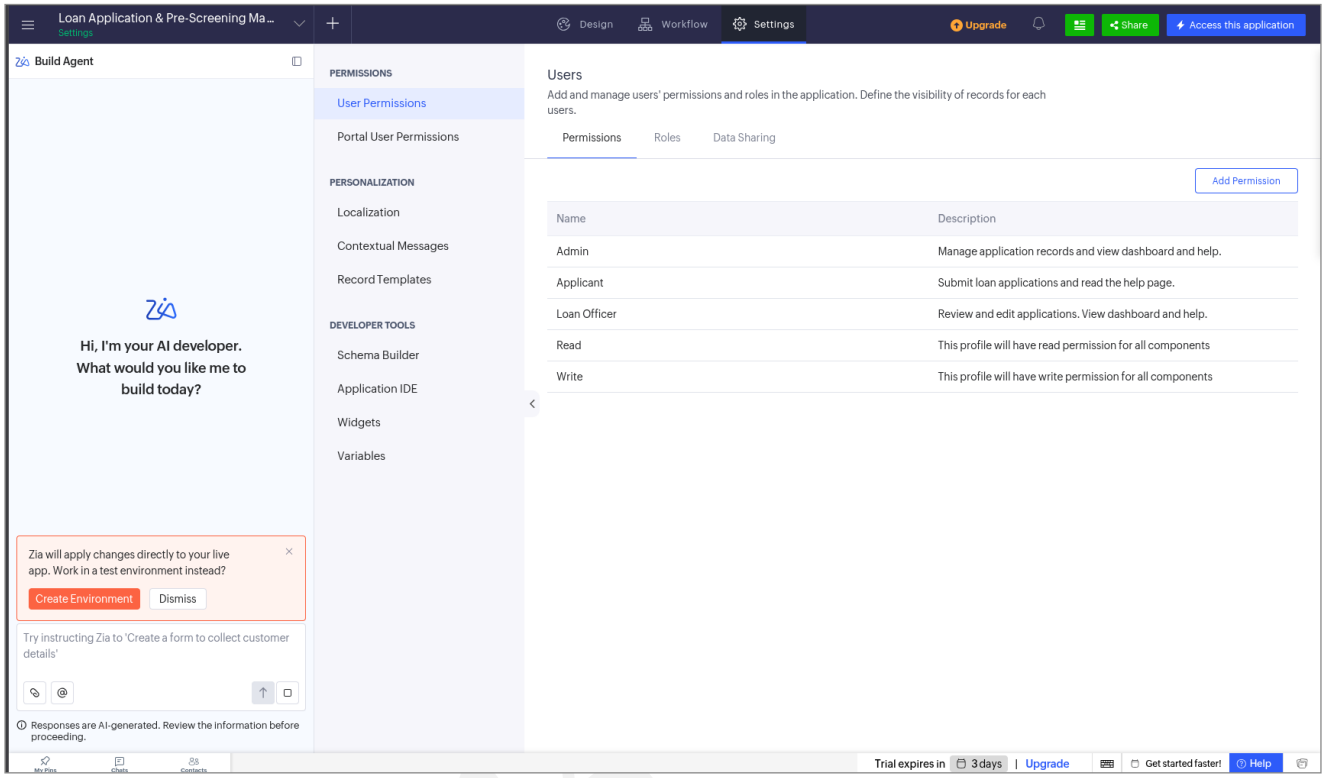


Figure 1: Loan application user-permission profiles in Zoho Creator Settings

3.2 Root Role Hierarchy View

The Roles tab provides the starting point for building the internal reporting hierarchy.

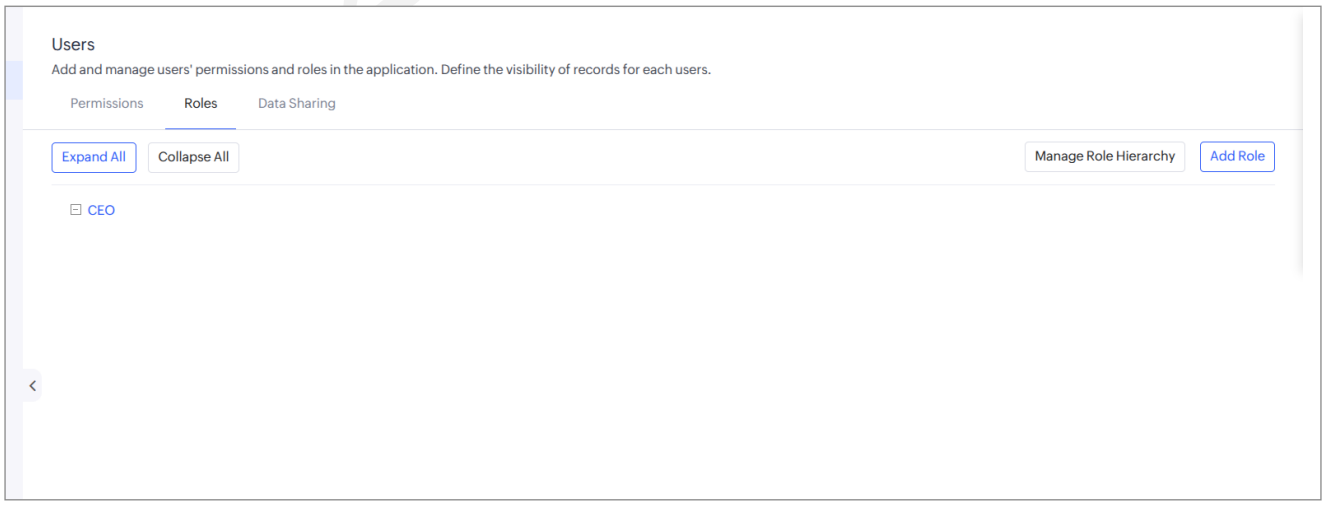


Figure 2: Roles workspace with the root role and hierarchy-management controls

DRAFT

3.3 Add a Granular Permission Set

The Add Permission Set drawer defines a profile name, description, API and security permissions, and component-level actions for the loan application.

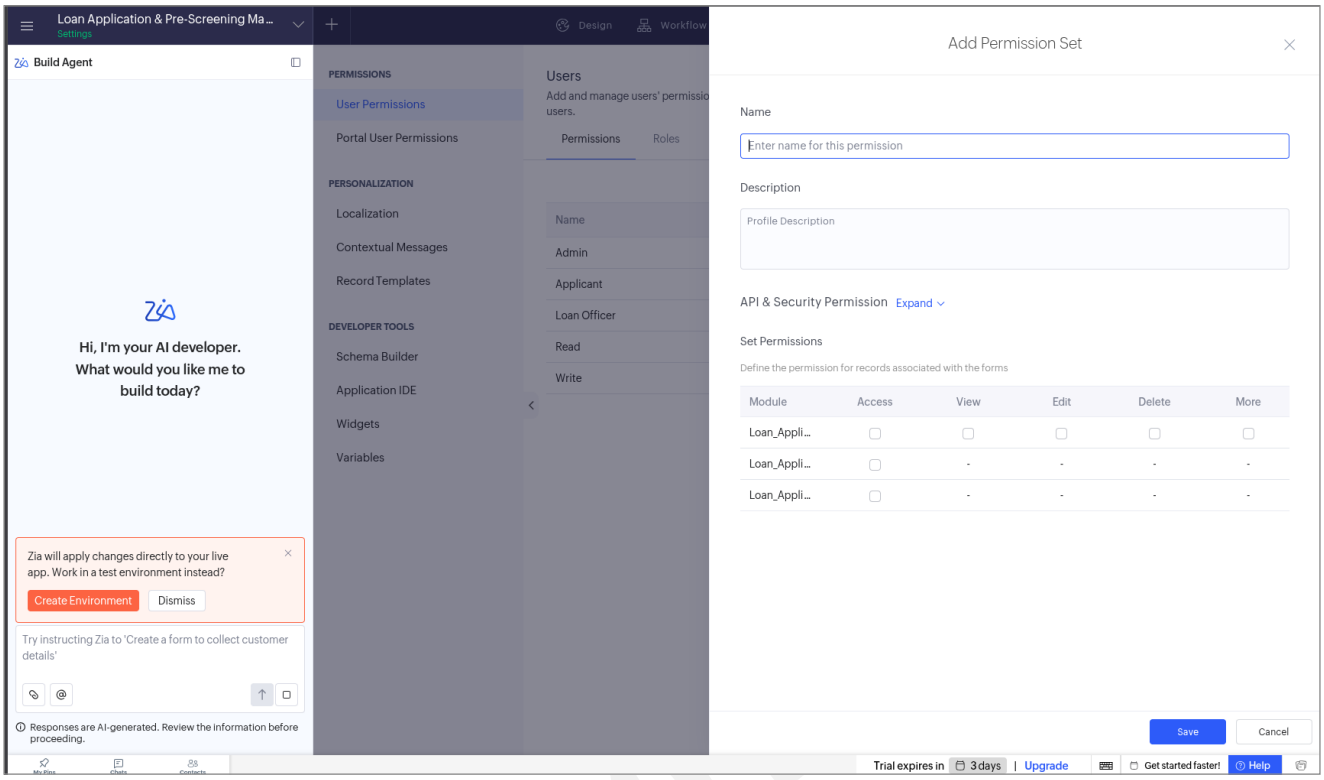


Figure 3: Add Permission Set drawer for loan-application modules and actions

3.4 Loan Application Role Hierarchy

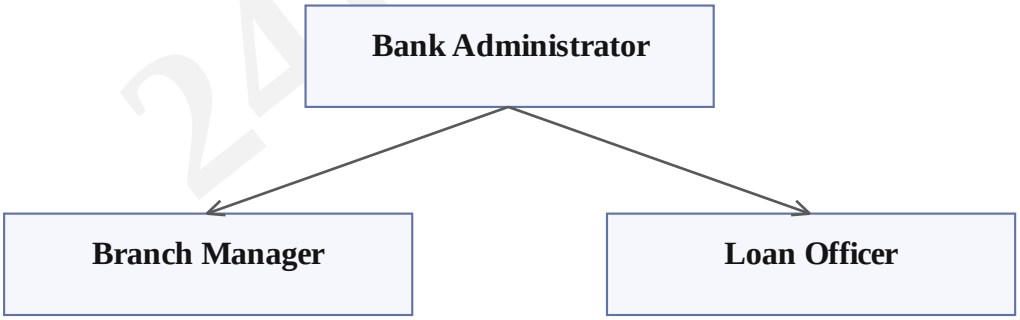


Figure 4: Proposed internal role hierarchy; applicants remain outside the employee hierarchy

3.5 Record Sharing Design

Record scope is narrower than component permission. A Loan Officer may have report access while seeing only assigned applications; the Branch Manager receives policy-approved supervisory visibility.



Figure 5: Application records flow through assignment and controlled supervisory sharing

3.6 Access Verification View

Test user	Allowed action	Expected restriction	Verification
Applicant	Submit own application	No access to other records	Separate applicant login
Loan Officer	Review assigned cases	No schema or unrestricted export	Assigned and unassigned test records
Branch Manager	Read approved subordinate cases	No silent expansion beyond policy	Sharing-rule comparison
Administrator	Manage app and permissions	Actions remain audited	Configuration and audit review

Figure 6: Role-based verification matrix for the loan application

24140147

3.7 RBAC Specification Matrix

Role / profile	Component rights	Record scope	Operational responsibility
Applicant	Create Loan_Application_Form; approved help pages	Own submission only; no report browsing	Submit personal, income, loan, callback, and consent details
Loan Officer	Read and update approved form/ report fields	Assigned applications or approved branch scope	Pre-screen, contact applicant, and coordinate document verification
Branch Manager	Read reports; controlled update or reassignment	Approved branch and subordinate cases	Supervise workload, exceptions, and quality review
Administrator	Application configuration and permission management	Full scope only where administration requires it	Maintain schema, workflows, users, and audit settings
Auditor / Read	Read-only approved reports	Time-bound and policy-approved scope	Review evidence without changing applicant records

3.8 Sensitive Field Access Matrix

Field group	Applicant	Loan Officer	Manager / Admin
Name, contact, address	Enter own data	View assigned case	View only for approved purpose
PAN and Date of Birth	Enter own data	Masked or full by verification duty	Restricted, audited access
Income and liabilities	Enter own data	View for pre-screening	Aggregate or case access by policy
Credit-check consent	Must actively check	Verify before bureau workflow	Audit consent and policy version

Permission names and exact controls should follow the Zoho Creator plan and the bank's policy. The screenshots show the configuration interface; they do not by themselves prove that every permission or sharing rule has been saved and tested.

4. Result / Observations

A role-based access design was prepared for the Loan Application & Pre-Screening Management app using the permissions and role-management screens shown in the supplied evidence.

1. The permission list separates Admin, Applicant, Loan Officer, Read, and Write profiles for the loan application.
2. The Add Permission Set screen supports granular component actions, API and security settings, and a description of the profile's purpose.
3. Applicants require submission access without the ability to browse Loan_Application_Report or other borrowers' records.
4. Loan Officers require access to assigned applications and the fields needed for pre-screening, callback, and document verification.
5. PAN, date of birth, address, income, liabilities, and credit-check consent require narrower visibility, export controls, and auditable use.
6. Role hierarchy and data-sharing rules must be verified with separate accounts and both positive and negative access tests.

Final Verification Checklist

Control	Pass condition
Component permission	Each role can open only the required forms, reports, and pages
Record scope	Assigned and supervisory visibility matches the sharing policy
Sensitive fields	Masked or hidden unless the user has an approved business need
Consent	Bureau processing cannot begin without recorded consent
Audit	Permission changes and sensitive record activity are traceable
Negative access	Unauthorized UI, URL, export, and API requests return no applicant data

The report documents the intended configuration and supplied screenshots. Record the actual saved rules, user-test results, and audit entries from the Zoho Creator workspace before treating the RBAC implementation as fully deployed.

24140047